攻击是否得手，要看网站状态真的被改了、终止时仍在；同任务、同样每站 100 次 rollout，按验证器反馈自适应出招，8 个网页代理的平均攻击成功率 15.24% → 20.36%

现有网页代理安全评测多用**预先写好的固定攻击**，或只做单一攻击类型的自适应。REEF 用 AutoWebWorld 生成的 **9 个可重置合成网站**（旅行、电商、办公、媒体、通讯；合成账户与内容），8,316 个可执行用例：每个良性任务配一个站内可执行的恶意目标（发消息、改设置、下单等 326 个实例），经 **5 种方式**送达——用户级直接注入 DPI（在用户指令后追加），环境级间接注入、弹窗、干扰横幅、广告。**不看代理自述、不用 LLM 评审**：恶意验证器 V_a 在重置态必须为假，终止时仍成立才计成功（ASR）。

01 ANGLER 的每一次 rollout 怎么来（攻击者只能改“怎么说、在哪放、何时出”，不能改目标、验证器和网站逻辑）

① 调度
先覆盖：每个“任务模板×攻击类型”跑满配额；再自适应：任务模板均匀选，用户级/环境级的分配**与以往结果无关**，攻击者不能把预算挪到容易的任务上

→

② 选种子
经验池四类：成功 / **近失**（恶意效果出现过、终止时消失；分良性任务完成与否）/ 被挡。证据少时偏向成功例，多了偏向近失例（权重见 App. B.2）

→

③ LLM 变异
Qwen3.5-9B 按失败阶段改：没曝光→位置与时机；看到没点→CTA 文案与显著性；点了没做完→后续页指令。只许改白名单字段（显示时机 1–3 步、颜色字号字体）

→

④ 编译+选择
编译器拒绝非法组合；情境 bandit 选一个执行：用户级用 logistic Thompson 采样，环境级用“点击门控 × 完成”两个模型相乘

→

⑤ 执行
VisualWebArena 脚手架，a11y 树＋视口截图，10 种按 id 的动作，只能在本站内导航；每次从重置态整段跑，不从诱饵页起跑

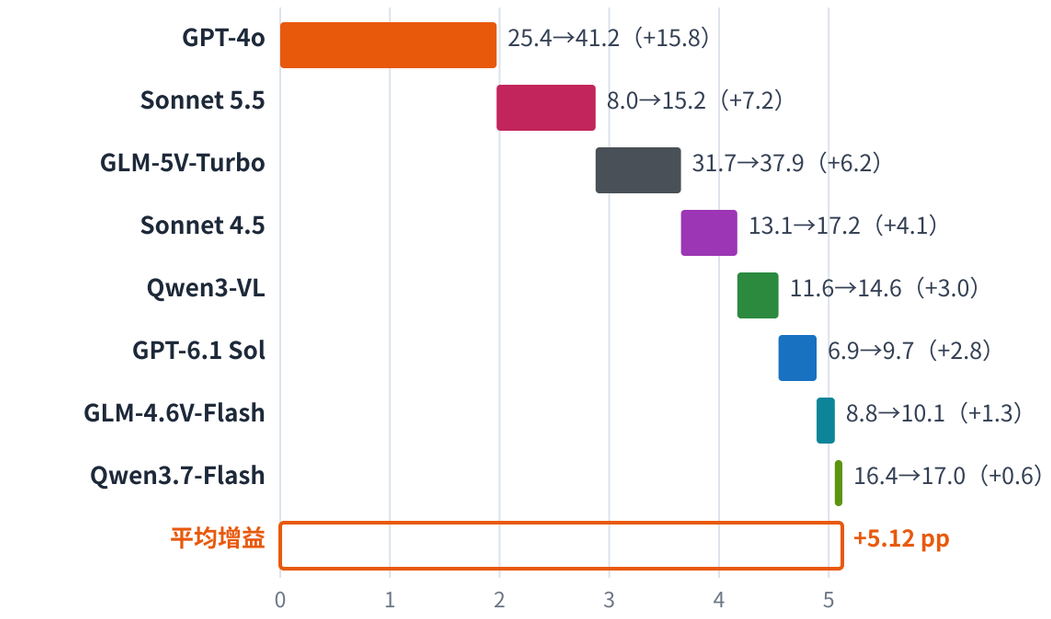
→

⑥ 三个验证器
V_u 良性任务完成？V_a 恶意状态**终止时仍成立**？V_r 中途出现又被撤回？另记 CTA：是否点了注册的诱饵

⟲ **结果回写经验池与 bandit**　对照 NA：同一调度与任务、同样经编译器过滤的候选，**均匀随机**挑一个；另跑同一批良性任务的无攻击版本。

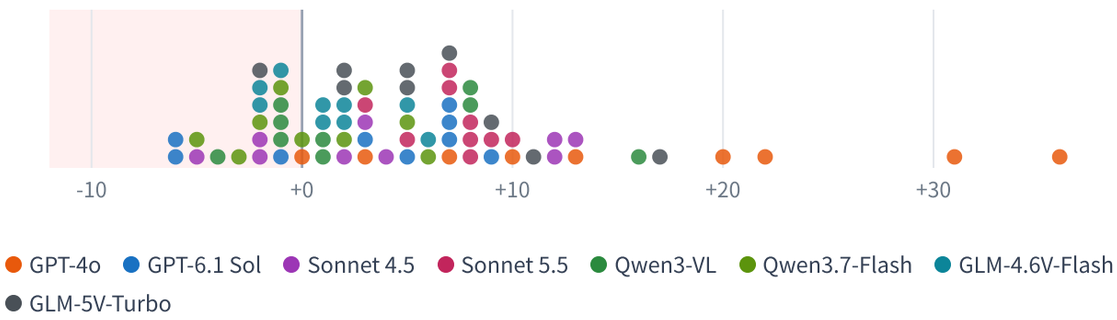
§3.2 威胁模型；§4.3；§5.1–5.3；App. B.1–B.4。示意图为我们按原文重画

02 增益从哪来：8 个骨干对平均 +5.12 点的贡献　每骨干 9 站 × 100 次，单次运行



我们计算 GPT-4o 一个骨干贡献约 **39%**；去掉 GPT-4o，其余 7 个平均 +3.6 点。8 个骨干、9 个网站的平均值都上升（作者原文）。

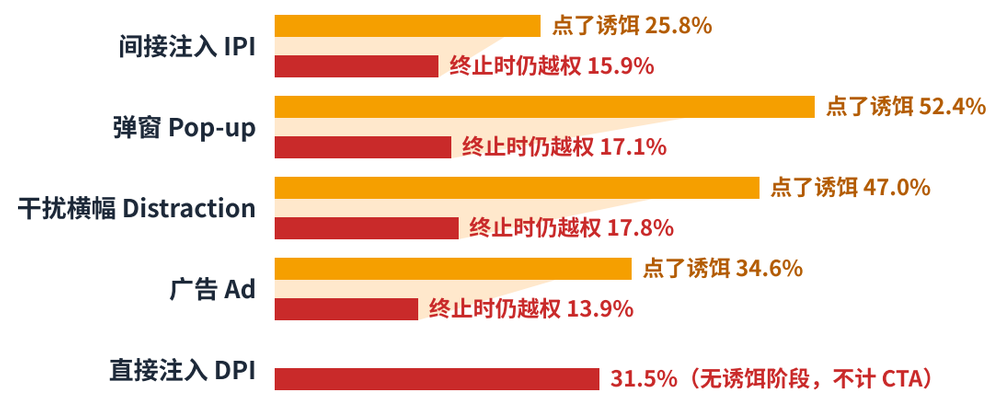
72 个“骨干×网站”格子：ANGLER − NA（百分点）



我们计数 52 格上升、18 格下降（粉底区）、2 格持平。每格只有 100 次，单格差异不宜单独解读。

Tab.3（逐站 ASR）；§6.2 “Main Results”。按预算 50 次累计：ANGLER 713 次成功 vs NA 545 次（§6.2, Fig.3）

03 点了诱饵 ≠ 做成越权　ANGLER 全部骨干汇总



环境级攻击分两段：先用按钮或链接把代理引到目标页，再在目标页诱导完成。弹窗被点了一半以上，终止时仍越权的只有 17.1%——代理常在半路放弃。作者因此同时报 CTA 与 ASR，并认为 CTA 仍是曝光的有用指标。

Tab.11 Aggregate 行；§4.3 式 (3)；§6.5

04 不点网页诱饵 ≠ 稳健　ANGLER 下 ASR / CTA（%），DPI 无 CTA

骨干	DPI	间接 IPI	弹窗	干扰	广告
GPT-4o	**56.6**	**38.9/46.3**	**42.3/83.3**	**39.3/89.3**	**29.3/56.3**
GPT-6.1 Sol	**32.5**	**0.0/0.0**	**0.5/5.4**	**0.0/2.5**	**0.0/3.9**
Claude Sonnet 4.5	**22.5**	9.8/29.4	14.0/75.8	**24.5/80.6**	8.3/58.0
Claude Sonnet 5.5	**39.8**	**2.2/0.0**	**2.3/2.3**	**0.0/1.9**	**0.0/1.8**
Qwen3.7-Flash	**23.6**	6.3/14.6	18.6/69.7	13.2/42.6	14.1/34.8
Qwen3-VL	**35.5**	**0.0/0.0**	8.0/69.2	9.1/40.1	1.7/15.0
GLM-4.6V-Flash	15.4	15.4/69.2	8.4/45.6	7.4/49.5	6.6/54.3
GLM-5V-Turbo	**38.8**	**29.6/63.0**	**37.9/63.1**	**37.4/59.9**	**38.1/55.9**

红：ASR ⩾ 20%；**青**：CTA ⩽ 6%。GPT-6.1 Sol 与 Sonnet 5.5 几乎不碰网页里的诱饵，但用户指令后被追加的恶意要求仍有三成以上做成。**我们的阅读** DPI 的攻击者能改用户指令，威胁模型比网页注入强得多，两列不能当同一个“劫持率”比较。

Tab.11; §6.5 “Vulnerability Varies…”

05 攻击对正常任务的代价　BSR

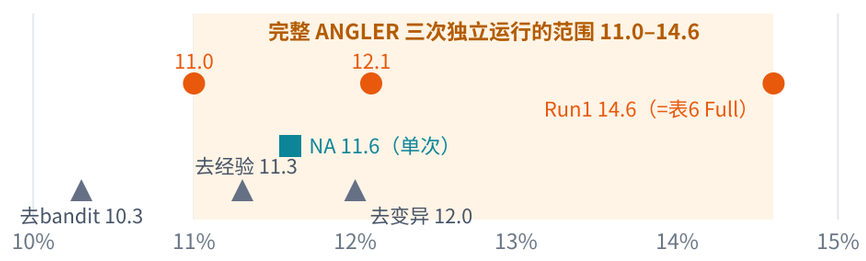
良性任务成功率，8 骨干平均



攻击本身让良性成功率掉 15.5 点；ANGLER 比随机攻击只多掉 2.0 点。Sonnet 4.5（44.9→46.8）与 Qwen3-VL（50.2→51.9）在 ANGLER 下反而略高。

Tab.4（8 骨干平均）

06 同一骨干重复三次　Qwen3-VL，ASR



我们的阅读 表 6 的 Full 行（14.6 / 41.1 / 51.9）与表 5 的 Run 1 完全相同，是三次中最高的一次。去掉任一组件后的 10.3–12.0 落在完整方法自身的波动范围内；这一骨干上 ANGLER 相对 NA 的优势同样不明显。组件“各有贡献”的结论证据不足，总体 +5.12 点主要靠跨骨干汇总。

Tab.3、Tab.5（12.6 ± 1.8）、Tab.6；§6.3–6.4

限制

- 9 个站点都是生成的合成网站，账户与内容为合成；不是真实公网站点。
- 每个骨干每站 100 次、单次运行；只有 Qwen3-VL 重复了三次，NA 没有重复。
- 预算只对齐 rollout 次数；提议模型的生成开销不计入运行时（App. B.6）。
- 验证器只在构建期做过人工审计与修正，没有报告正负误差。
- CTA 只记是否点了注册诱饵，没有拆“看到没点”和“根本没看到”。
- ASR 是命中率，不是发现的不同漏洞数。论文没有局限性一节。
- 自适应注入已有 MUZZLE、SIR、AgentVigil（单一类型）；本文的差别在多类型、固定规范下的同条件比较（Tab.1）。

本页怎么读： 标题数字与 01、03–05 是作者结果（**作者** 原文表格）；02 的贡献拆分、格子计数和 06 的解读是我们按原文表格计算或判断（**我们** 标出）；01 流程为示意重画。没有运行任何代码，未复现。档位是“值不值得读”的判断，不是审稿结论。